Version-Aware Evidence Contracts for Local Security Alert Explanations

Ananay Srivastava, Jitendra Singh, Manik Bhardwaj, Ashish Jain, Mukunj Singh

Department of Computer Science and Engineering, Sharda University, Greater Noida, India

***Abstract*—A local language model can misrepresent a security alert when authorized evidence is incomplete, contradictory, or later withdrawn. We implement a finite claim contract over versioned recipient-specific snapshots. An independent validator admits only claims matching authorized evidence identifiers, exact versions, scope, and permitted predicates; displayed text is rendered from controlled templates. Snapshot changes make dependent reports stale. One repair attempt is allowed before a deterministic fallback. In an eight-case frozen CPU pilot with Qwen3-4B Q4_K_M, direct generation produced 10 unsupported claims among 20 claims, citation-prompted generation produced eight among 20, and verification without lifecycle checks retained three unsupported claims among 48. The complete method emitted no unsupported claims among 46, but fell back in all eight cases; median generation time was 146.7 seconds. These results show a safety boundary and a severe usability limitation, not a demonstrated benefit from model prose. No analyst study or field accuracy result is claimed.**

***Index Terms*—security alerts, local inference, evidence versions, claim verification, abstention**

I. Introduction

An alert may state that an authentication anomaly occurred while withholding identities, source addresses, or exact counts. A fluent explanation can fill these gaps with plausible details that the alert never established. Running the model locally changes where inference occurs; it does not make the resulting statements faithful to the supplied evidence.

Local cybersecurity models such as Hackphyr and RedSage establish relevant model capabilities [1], [2], while citation evaluation and post-generation revision are already studied in ALCE and RARR [3], [4]. The question here is narrower: how should a security explanation preserve unavailable, disputed, and revoked evidence instead of silently turning it into a complete narrative?

We implement a typed claim contract and a versioned report lifecycle. The contract restricts statements eligible for deterministic rendering, retains unresolved claims, and records dependencies for later invalidation. It does not make a language model an authoritative detector. A small frozen pilot tests claim support and latency; no analyst study or field validation has been completed.

II. Related Work and Claim Boundary

FActScore evaluates support at the level of atomic claims [5]. LEXIS produces structured security report drafts from classifier explanations [6]; agentic alert investigation uses constrained queries over logs [7]. GSAR combines typed grounding assessment and bounded recovery [8]. A recent agent-memory study finds that soft revocation labels alone can leave withdrawn information available to a generator [9]. Thus citations, structured reports, local inference, and bounded rewriting are not individually novel contributions of this manuscript.

SHAP-based cybersecurity interpretation explains influential detector features [10]; it does not by itself validate an analyst-facing factual claim. RefChecker extracts claim triplets and checks them against references [11], while SelfCheckGPT uses agreement among sampled responses to detect hallucination [12]. Our verifier instead admits exact tuples from a finite, recipient-authorized snapshot. Agreement among model samples cannot restore withdrawn permission. FaithLM evaluates whether explanations reflect model decisions through interventions [13]; our evidence-fidelity test does not establish that form of causal explanation faithfulness. These distinctions limit the novelty claim to authorization and evidence-version enforcement in a local security-report pipeline.

Our focus is a security-specific evidence-state contract: an unavailable field cannot justify a negative factual assertion, a contradiction must remain visible, and withdrawal invalidates dependent claims. This is a candidate methodological contribution whose usefulness needs comparison against existing structured reporting and typed grounding approaches. The pilot does not show superiority to these systems.

In the implemented contract, a recipient-authorized snapshot contains an incident outcome, anomaly family, coverage flag, and a list of evidence entries with identifiers, versions, activity flags, and finite catalogue values. The authorized snapshot has a digest. Corrections change a value or version; withdrawal makes an entry inactive; a new digest invalidates the old report. The present finite vocabulary does not encode arbitrary intervals or numeric units in model claims. Those are extensions, not properties established by this experiment.

A proposed claim is $c = (t, p, v, e, k)$: claim type t, predicate p, value v, optional evidence identifier e, and optional evidence version k. Types are observation, inference, unknown, and advice. Predicates in the pilot are evidence value, outcome, family, coverage, and a fixed local-log-review suggestion. A claim that names an attacker, exact count, or successful compromise is not admissible merely because a related anomaly is present; those predicates are absent from the vocabulary.

The explanation service has no authority to change the

detector score, request forbidden raw records, or execute recommendations. It consumes a frozen authorized snapshot and returns a report. An upstream detector can be wrong; the contract concerns fidelity to its evidence, not independent verification of the incident. A malicious evidence producer or a false but internally consistent record can still mislead the service.

III. Admission and Report Lifecycle

The server first constructs a recipient-authorized snapshot. A local model proposes typed claims and supporting identifiers. The verifier compares every claim tuple against a set derived deterministically from that same snapshot. This checks value equality, reference and version equality for evidence values, and the permitted claim kind for the finite predicates. Recipient scope is enforced when the snapshot is built and checked again before a report is returned. The pilot does not use a general entailment model or interval algebra.

For that vocabulary, define an admission indicator

$$A(c, E) = R(c, E) \wedge V(c, E) \wedge K(c, E) \wedge P(c, E), \quad (1)$$

where R checks evidence identifiers, V checks versions, K checks claim kinds, and P checks the finite predicate/value tuple. The authorized snapshot E is a precondition. Admission proves only that these configured checks passed. It does not certify the truth of the source evidence or any unrestricted language-model interpretation.

An admitted factual claim is rendered using a controlled template, preserving its evidence identifiers and uncertainty wording. Free-form model commentary is omitted. A citation attached to arbitrary prose is insufficient for admission. For example, a high failure-rate bin may be reported as an authorized observation, but it cannot become "the attacker tried 300 passwords."

If a proposed claim fails, the service requests at most one rewrite using the same frozen snapshot and the check failures. It does not acquire broader permissions during rewriting. If the rewrite fails or inference is unavailable, a structured fallback lists permitted observations and explicit unknowns without model-generated interpretation. This bounded recovery limits the number of calls; it does not establish hallucination freedom or a short latency bound.

The report stores the snapshot digest and the evidence identifiers and versions supporting admitted claims. A correction, authorization withdrawal, or revocation changes the authorized snapshot digest; an old report is stale and must be regenerated. An already viewed report cannot be erased from an analyst's memory. Detection decisions remain under the upstream security workflow's control.

IV. Constructed Cases and Contract Properties

Suppose authorized record E1 states that a high authentication-failure-rate bin occurred in a five-minute interval. E2 states that source identities are unavailable. E3 is a rule output labelling the event suspicious. No record establishes a successful login or identifies a threat actor. These are invented records used to illustrate the contract.

The statement "the sensor reported a high authentication-failure-rate bin during the interval" is admissible with E1. "The rule labelled the event suspicious" is admissible as an attributed inference with E3. "No external sources were involved" is not justified by E2. The correct statement is that the available evidence does not establish source identities. "A named actor compromised the account" is rejected because neither attribution nor compromise is supported.

Now suppose E1 is corrected to a medium-rate bin. A report citing the old version becomes stale. Replacing the evidence reference without updating the claim would be invalid. If E1 is revoked and its value is no longer authorized, the next report cannot repeat that value through a cached explanation. A permitted status may say that the earlier explanation is no longer supported by the current authorized snapshot, without exposing the withdrawn value.

a) Reference integrity.: Every admitted factual claim points to existing authorized evidence versions because reference resolution precedes rendering. This property assumes the validator and snapshot store operate correctly. It is not a guarantee that a cited record actually describes a real event.

b) State preservation.: The finite claim vocabulary prevents an unavailable input from licensing a negative observation and prevents an inferred record from licensing an unattributed fact. The guarantee covers controlled templates only. If unrestricted paraphrasing is allowed after admission, the paraphraser can change the meaning and must be treated as a new unverified generation.

c) Invalidation completeness.: A dependency index can identify every stored claim referencing a changed evidence version if all references are recorded. Rechecking is then mandatory before reuse. This does not guarantee that every implicit dependency was captured, nor does it retract information already disclosed. The design therefore prohibits hidden factual dependencies in admitted claims and treats unsupported free text separately.

V. Implemented Service Boundary

The explanation process is downstream of detection and incident correlation. It receives a snapshot prepared by the incident API for a particular analyst's organization and permission scope. The snapshot contains a digest, a categorical outcome, anomaly family, coverage state, and active evidence entries. Each evidence entry is a finite-catalogue value with an identifier and version. This interface deliberately excludes raw packet captures, unbounded log search, and a model-controlled query tool. A generator cannot request broader evidence by returning a new identifier. The API checks its authorization rules before assembling the snapshot; the explanation verifier checks the proposed identifiers against the assembled snapshot.

The model endpoint is an interchangeable local service rather than a hidden dependency of detection. The configured call uses JSON output, a maximum of 512 output tokens,

TABLE I
FINITE PILOT CLAIM CONTRACT AND RENDERING RULE.

Predicate	Kind	Admission condition
Evidence value	observation	Exact active evidence ID, version, and value
Outcome	inference	Exact incident rule outcome
Family	observation	Exact reported anomaly family
Coverage	observation or unknown	Exact full/partial coverage state
Review logs	advice	Fixed advisory value only

TABLE II
UNSUPPORTED CLAIM COUNTS BY SYNTHETIC CASE.

Case	Direct	Cited	No life.	Complete
Supported	1	1	0	0
Contradicted	3	0	0	0
Unresolved	0	0	0	0
Withdrawn	2	2	1	0
Corrected	0	2	1	0
Restricted	3	2	1	0
Malicious note	1	1	0	0
Model failure	0	0	0	0

a prompt-size cap, a response-size cap, one generation at a time, and a timeout. A failure does not remove the incident or change its outcome. It produces a template report from current authorized fields. When inference runs on a second laptop, the endpoint requires authenticated TLS; the local experiment used a loopback endpoint. The experiment therefore measures local generation behavior, not network transport to a second device.

Table I is intentionally small. The outcome statement is attributed to the declared correlation rule, not asserted as a confirmed compromise. Partial coverage renders as an unknown, so absent evidence does not become a claim that no threat exists. Advice is a separate kind and a fixed suggestion to review local logs; it neither queries those logs nor authorizes action. The table also exposes a limitation: an arbitrary but true security fact cannot be expressed unless the catalogue and verifier are deliberately extended. In particular, exact counts and named actors are outside the evaluated claim language.

The generator receives the snapshot as untrusted data along with the output schema. An evidence value may contain instruction-like text, but the model has no attached file, network, or shell tools. The validator does not trust the model's citation format alone: every proposed tuple must equal a permitted tuple computed from the snapshot. The renderer then produces its own sentence; it does not copy an arbitrary sentence supplied by the model. This separates two error classes. The model may emit a syntactically valid but unsupported claim, which fails membership, or it may emit invalid JSON or an invalid claim schema, which fails structural validation. Both are observable failures, not silent omissions.

The one-repair policy keeps the authorized snapshot fixed and gives the model a bounded list of check failures. It is a recovery attempt, not a second source of evidence. If either generation fails, the final output is generated from deterministic expected claims. The fallback's exact wording is less expressive than a skilled analyst's report, but its behavior is explainable and reproducible. A default fallback can be preferable when the local model is too slow or unreliable; a deployed system should not hide how often that path is taken.

VI. PILOT CASES AND SCORING

The eight cases were specified in a frozen JSON file whose digest is checked by the evaluation script before inference. They cover a supported case, a contradicted case, partial coverage, withdrawn evidence, corrected evidence, restricted evidence, instruction-like text in an evidence note, and a deliberate model failure. For a lifecycle case, each record has an initial snapshot and a current snapshot. The cited condition generates from the initial one; scoring uses the current one. This exposes stale or unauthorized claims without pretending that a prompt can foresee a later revision. The complete method regenerates from current authorized values after invalidation.

The score counts claims present in the model's structured output, and calls one unsupported when it is not admitted against the current finite contract. Unsupported does not mean that a human reviewer proved the sentence false; a claim can fail because its evidence is expired, unavailable to this recipient, or outside the implemented vocabulary. The direct and citation-prompted conditions are therefore useful stress tests of this contract, not measures of general factual accuracy. Conversely, a deterministic template scores perfectly because it is built from the same expected set. This shared construction makes the safety comparison transparent while preventing a claim of independent validation.

The no-lifecycle ablation is paired with the cited condition by reusing its raw output and applying verification against the initial snapshot. This avoids attributing a difference to a fresh random model sample. It then scores the resulting report against the current snapshot. Three claims remain unsupported: one each in withdrawn, corrected, and restricted cases (Table II). The complete path detects these changed snapshots and falls back to the current template. For unchanged cases, it may attempt one repair; every case ultimately fell back. The complete result is thus a demonstration of version enforcement coupled to a negative result about the model's ability to satisfy the contract in this configuration.

The CPU host was Windows with an AMD Ryzen 5 4500U, six logical processors, about 20.9 GB of RAM, four inference threads, and one concurrent generation. The configured context length was 8192. These settings and the 4-bit quantized Qwen3-4B variant specify the measured configuration; they do not establish that other devices, quantizations, or model sizes will behave similarly. A separate small-model memory check recorded about 2.96 GB peak process working set for Qwen3-1.7B Q4_K_M; it is not a memory measurement of the 4B pilot and is not used to claim a 4B footprint.

TABLE III
WHAT EACH COMPARISON CAN AND CANNOT ESTABLISH.

Comparison	Interpretable conclusion
Direct vs. cited	Effect of this citation instruction on finite-contract errors; model samples remain stochastic
Cited vs. verifier	Whether exact schema and tuple checks remove unsupported candidates
No lifecycle vs. complete	Whether current-snapshot validation prevents stale reuse in changed cases
Template vs. complete	Added generation cost and observed output difference; no human usefulness inference

VII. Research Questions and Comparator Semantics

The first research question asks whether finite claim admission prevents an explanation from expressing specificity absent from the recipient's current snapshot. It is evaluated by unsupported tuple counts, invalid-contract cases, and fallback rates. The second asks whether a current-version check prevents reuse of claims that were once authorized but no longer are. It is evaluated by the paired no-lifecycle ablation and three changed-snapshot cases. The third asks whether the model yields useful additional information at acceptable cost. Our data do not answer that question because both the template and complete method used the same expected-claim set and no analysts evaluated the outputs. These questions must not be collapsed into a single "explanation accuracy" number.

The template comparator constructs allowed claims without inference. It is the safety and speed reference, and its perfect finite-contract score is expected by construction. Direct generation receives the same snapshot but no explicit instruction to cite each evidence value. Citation prompting adds evidence identifiers and versions to the prompt. Neither prompt condition is allowed to query missing data. The no-lifecycle condition applies the claim checker to an initial snapshot and then tests the result against the current snapshot; this isolates the risk of assuming that one successful check stays valid indefinitely. The complete method validates the current snapshot, attempts at most one repair for unchanged inputs, and emits the deterministic fallback when no valid generation is available. The comparator definitions are explicit so a lower error count cannot be mistaken for better natural-language reasoning.

Atomic claim scoring is sensitive to the output representation. A direct answer could contain a long paragraph, but the pilot asks all model conditions for structured claims so that unsupported output can be counted with the same parser. Invalid JSON is reported separately from unsupported claims because assigning an arbitrary factual count to unparseable text would invent observations. Failure cases likewise remain visible. This protocol narrows the study to structured generation; it does not establish what the same model would do in unrestricted conversation.

The mean finite-claim coverage in the summary file uses the allowed claim set as its denominator. It is a completeness check for this schema, not evidence that the analyst received the right explanation. For example, a report can enumerate all allowed fields while giving no practical priority or useful next question. Conversely, a concise report could omit low-priority allowed fields while helping an analyst. A follow-on human evaluation should measure task accuracy, time, and uncertainty recognition. It should be preregistered and sampled beyond these eight constructed cases.

VIII. Adversary and Failure Model

Indirect prompt injection can place instructions inside externally supplied data [14]. Therefore evidence notes remain untrusted inputs even when the producer is authenticated. Local execution also differs from confidential computing: accelerator trusted execution environments protect workloads from an untrusted host [15], whereas our CPU pilot assumes a trusted host and provides no hardware attestation. An untrusted sensor note may contain ordinary data mixed with imperative text. The model may obey that text even when prompted to ignore it. The verifier's defense is narrower and testable: a note cannot introduce a new permitted claim tuple or create an authorized evidence ID. A malicious source that controls an otherwise authorized finite value can still make a false observation appear valid. Such source compromise is outside the explanation contract and must be handled by detection, provenance, and incident review. The contract prevents unauthorized *expression* from a snapshot; it does not authenticate reality.

There are three distinct stale-data paths. First, a corrected record may retain the same identifier while its version and value change. Second, a withdrawal may make a previously active record unavailable to this recipient. Third, the recipient's role or organization scope may change without a sensor correction. All three require a fresh authorization check before serving a cached report. A digest mismatch is a coarse invalidation rule: it invalidates an entire report even if a changed entry was not mentioned. That costs regeneration but avoids claiming a more precise dependency analysis than the implementation provides.

The generated output is another untrusted boundary. The parser rejects an invalid JSON shape; the checker rejects wrong kinds, predicates, values, references, or versions; the renderer maps admitted claims to fixed wording. Errors are recorded and may trigger one retry. A service timeout, malformed response, or unavailable model maps to a visible fallback reason. This fail-closed behavior depends on the verifier being outside the model and on the snapshot store enforcing recipient access. It is not obtained from the prompt's wording alone.

The dashboard is a disclosure surface. A report that is correct for one analyst may be unauthorized for another. Therefore the API checks incident scope and report scope, and the explanation cannot be treated as a shareable string detached from those scopes. Telemetry should record status, duration, and failure class without serializing prompts, credentials, or raw evidence. The present measurements do not include a full privacy attack or side-channel analysis. In particular, a derived evidence value can itself disclose sensitive information, and

TABLE IV
FROZEN EIGHT-CASE LOCAL PILOT; COUNT DENOMINATORS ARE SHOWN.

Condition	Claims	Unsupported	Fallbacks	Median s
Template	46	0	0	< 0.01
Direct	20	10	0	53.0
Cited	20	8	0	86.6
Verify only	48	3	8	–
Complete	46	0	8	146.7

a local model process can retain data in memory or logs if configured poorly.

Operational failures also affect interpretation. A slow model may leave the security decision available but delay explanatory text. A missing database or broken authorization check should prevent a current report from being served. A cached report can be useful for audit under a separate retention policy, but it cannot be silently presented as current. These outcomes are testable at the API level and should be distinguished from the model's claim quality. The pilot measures one local inference configuration; it does not measure concurrent analyst demand or second-laptop transport failure.

IX. Evaluation and Limitations

The evaluated Qwen3 model belongs to a family with distinct model sizes and thinking modes [16]. Published local–cloud offloading work optimizes quality, latency, and usage cost jointly [17]. Our experiment fixes local execution and uses deterministic fallback on failure; its measured latency does not compare cloud offloading or prove an optimal deployment choice. We froze eight synthetic cases before running the five conditions: deterministic templates, direct local generation, citation-prompted generation, verification without lifecycle checks, and the complete method. The cases exercise unavailable fields, contradictory observations, corrected or withdrawn evidence, and malicious strings embedded in evidence. The same snapshots and Qwen3-4B Q4_K_M local CPU configuration were used where generation was applicable. Direct and citation-prompted outputs were scored as atomic claims; the other conditions used the finite claim schema. The validator is an exact contract check, not a human semantic judgement.

Table IV reports aggregate counts across the eight cases, not estimates over a population of incidents. Direct generation had one failed case and two invalid-contract cases; cited generation failed in three cases. The no-lifecycle ablation retained three unsupported claims that a current-snapshot check would reject. The complete method produced no unsupported claims but used deterministic fallback in every case. The latency is the median measured generation time, not end-to-end analyst task time; the no-lifecycle condition reused cited output and has no independent timing measurement. Thus the experiment supports a narrow claim about contract enforcement while showing that this model configuration added no demonstrated benefit over templates.

The distribution in Table II matters as much as the aggregate. The contradicted case contributed three direct unsupported claims but no cited unsupported claims, while the corrected case contributed two cited unsupported claims and no direct unsupported claims. Citation prompting thus did not consistently improve each evidence condition. Withdrawal, correction, and restriction each left one unsupported claim after initial-snapshot verification. The complete method's current-snapshot check removed all three by invalidating the earlier view and using a current deterministic report. These counts come from one output per case and condition; they are not a confidence interval for future model behavior.

The deliberate model-failure case produced no model claims, so counting it as zero unsupported without also reporting the failure would reward nonproduction. Likewise, a fallback's supported claims are generated by a known finite constructor rather than by successful model reasoning. We therefore report raw claim counts, failure cases, and fallback cases together. The direct condition had 20 claims over the eight cases; the complete condition emitted 46 after fallback. A larger count in the complete output is not automatically an improvement: it reflects the template's enumeration of allowed fields, and no analyst has rated whether all of those fields were needed for a decision.

The repair attempt is deliberately bounded. For unchanged snapshots with rejected cited output, it can propose a corrected claim list from the same evidence. In this run none of those repairs led to a complete model-rendered report. The complete condition's 146.7-second median generation time includes the cited attempt and, when made, the repair; it is not the time to create the fallback text alone. It would be misleading to compare that number with the template's sub-0.01-second median as if both performed identical computation. The difference instead measures the operational cost of attempting model generation before taking the safe fallback path.

There is also an asymmetry in what these tests can falsify. A single unsupported displayed claim would violate the finite admission guarantee for that run. A run with no such claim does not prove the program correct for all possible inputs, and it certainly does not prove that the underlying incident was malicious. Integration tests exercise additional invalid identifiers, versions, and permissions, but a formal proof or exhaustive state-space test is outside this work. The pilot should be interpreted as a small, reproducible check of implementation behavior and a guide to the more demanding study that would be needed for a publication-strength usefulness claim.

The measured finite-claim coverage was 1.0 for template and complete, 0.979 for no-lifecycle, 0.221 for direct, and 0.267 for cited. This is coverage against the programmatic expected-claim set, not analyst usefulness. It rewards exhaustive template enumeration and is unsuitable as a human quality metric. The raw case records, evaluation code, machine description, and hashes are included with the repository. No independent analyst labels, field deployments, or full latency distribution are available.

The contract cannot repair inaccurate source evidence, establish missing causal links, or guarantee the soundness of arbitrary prose. Its finite predicate vocabulary restricts

expressiveness, and conservative admission can omit useful explanations. Recommendation usefulness requires a separate analyst evaluation. Prompt injection is reduced by treating evidence as data and denying model tool authority, but the generator can still produce misleading output before verification. Only the checked, controlled statements receive the stated contract guarantee.

X. Evidence States and Permitted Language

Observed evidence licenses a statement about what a sensor or record reports within its scope. It does not automatically license a statement about the whole environment. A source that monitored one subnet for five minutes cannot support "the organization had no other suspicious activity." The report should preserve the subject, covered interval, measurement units, and observation limits instead of expanding them during summarization.

Inferred evidence requires attribution. If a detector labels a window anomalous, the explanation can report that decision and its recorded basis. It should not convert the label into confirmed malicious behavior unless independent evidence establishes that claim. Likewise, a feature attribution explains a model's response to its inputs; it is not a causal account of an attack. The typed distinction between observations and inferences prevents that escalation within the controlled rendering path.

Unavailable evidence licenses an explicit statement of uncertainty where such a statement is authorized. A missing address field cannot support an assertion that no address existed. A withheld count cannot support a zero count. The service should use wording such as "the authorized record does not establish the count," which identifies the limit of the available evidence without speculating about why it is absent.

Contradicted evidence needs both sides preserved when both are authorized. A useful report can state that two records disagree about an event interval or status, cite them, and defer the disputed conclusion. It should not silently choose the more detailed record or the one appearing later in the prompt. If the conflict is resolved upstream, the resolution arrives as a new evidence version with an explicit basis; the language model does not adjudicate it by fluency.

Revoked evidence is ineligible for new factual claims. The status of a revoked report may itself be sensitive, so the outward-facing explanation follows the current authorization policy. Local audit can retain details under a separate retention basis, but the explanation service must not treat an audit archive as a source it can freely query. These state rules are proposed semantics for a bounded workflow, not a universal taxonomy of knowledge. The current implementation uses active/inactive evidence versions and a partial-coverage flag rather than encoding every state as an independent claim kind.

XI. Generation and Verification Boundaries

The model's role is to suggest a useful ordering and grouping of permitted facts and to propose typed statements. The validator's role is to decide which of those statements the restricted renderer may assert. Keeping these responsibilities separate makes failure visible. It also avoids claiming that a model checking its own answer supplies independent evidence of correctness.

The implemented finite predicate check compares claim fields to authorized values and exact evidence versions. A richer implementation might check count units, interval containment, or attributed rule outputs, but those extensions were not tested here. It cannot generally verify arbitrary causal prose. "This pattern is consistent with credential guessing" is a hypothesis whose support depends on a threat model and alternative explanations. The service may render it only as an attributed inference from an authorized rule.

The generation prompt should state the fixed output schema, allowed claim types, authorized evidence identifiers, and the prohibition on treating evidence text as instructions. Those measures alone are not a security proof. A malicious record might contain an instruction to ignore the schema, reveal prior context, or invent a conclusion. The model has no access to secrets outside the snapshot and no execution tools, and failed output is refused by the structural validator. This bounds available capabilities while acknowledging residual generation errors.

One rewrite is permitted after failure. The rewrite receives only the current snapshot and a list of failed checks, not privileged validator internals or new evidence. Repeated attempts could consume unpredictable time without adding support. A fixed rewrite limit and a deterministic fallback make the operational outcome defined even when the model cannot produce an acceptable claim list.

The fallback is a serious comparator rather than a cosmetic error message. It lists authorized observations, rule outcomes, and coverage gaps with fixed wording. In this pilot it matched the complete method's zero-unsupported count while avoiding model latency. Without a human study, there is no evidence that model-assisted ordering earns its cost. The research question is whether generation can improve analyst comprehension while preserving the contract.

XII. Closest Work and Scope of Difference

Hackphyr studies a locally deployable cybersecurity language model, so local execution by itself is not a contribution here [1]. RedSage likewise investigates a cybersecurity-generalist model [2]. ALCE studies citation-bearing language generation, but a cited sentence can still overstate what its source proves [3]. RARR revises model statements using research and revision stages [4]. FActScore decomposes long-form output into atomic factual claims for evaluation [5]. GSAR already frames grounding as typed assessment with recovery [8]. Our distinct, limited design choice is to take the authorized snapshot and evidence version as part of the claim's validity condition, then render a finite security vocabulary outside the model. We have not compared implementation quality or analyst outcomes head-to-head with those systems.

This comparison is deliberately about mechanisms, not novelty by exclusion. A system can combine several of these

TABLE V
RELATIONSHIP TO CLOSEST METHODS; ABSENCE MEANS OUTSIDE THE CITED METHOD'S EVALUATED FOCUS, NOT IMPOSSIBILITY.

Work	Relevant capability and distinction
Hackphyr	Local security model; no result here establishes a better model
ALCE	Citation generation; this contract checks finite claim values and current authorization
RARR	Post-hoc revision; this service limits repair to one and can abstain
FActScore	Atomic-claim evaluation; our checker is an admission gate over a narrow schema
GSAR	Typed grounding/recovery; our pilot tests evidence-version invalidation in alert reports
Revocation study	Demonstrates risk of weak revocation enforcement in agent memory

capabilities without using our exact interface, and new work may already cover part of it. The paper should be judged on the stated contract, executable verifier, and evidence that the lifecycle check matters in the defined conditions. It should not be read as claiming that citation checking, bounded repair, local models, or revocation were first introduced here. A stronger research claim would require a fair implementation comparison on the same alerts and recipient policies.

XIII. Why the Claim Vocabulary Is Finite

A general natural-language entailment system would allow more expressive reports, but its own errors would be difficult to separate from generator errors. In a security setting, an apparently small wording change can alter the decision: "observed many failures" differs from "an attacker attempted many passwords," and "no authorized source address was supplied" differs from "no external source existed." The finite vocabulary avoids that ambiguous boundary for the pilot. It makes admission a testable membership relation against current records. Its cost is a restricted output space that often resembles a template; the experiment's fallback result makes that cost visible.

The allowed tuple set is computed from the current snapshot, not inferred from the model's citation text. If evidence e has version k and value v, the permitted evidence observation is the exact tuple $(\text{observation}, \text{evidence_value}, v, e, k)$. A model claim with the right identifier but wrong version fails. A claim with the right version but a different value also fails. A duplicate claim is emitted at most once. If no factual claim survives, the report falls back rather than presenting an advice-only answer as though it explained an alert. These choices are simple enough for unit tests and for an analyst to audit.

The incident outcome and family are snapshot fields rather than external evidence IDs in the pilot schema. An outcome claim is explicitly rendered as a statement about the declared correlation rule. A family claim states the reported anomaly family. This attribution is essential: the architecture may correlate several signals, but the explanation component does not independently verify their provenance or security meaning. The phrase "declared rule" keeps that boundary visible to the reader. Future extensions could attach individual supporting signal IDs to rule outcomes, but doing so would change both the snapshot schema and verifier and would need new experiments.

The unknown claim represents partial evidence coverage. It is not an estimate of the probability of attack, and it does not say how many records are missing. It prevents a common failure in which the report turns an empty field into a reassuring negative assertion. In a richer deployment, coverage might be expressed per sensor, time interval, or predicate. That would improve precision only if the source accurately records what it monitored. Adding labels without reliable upstream measurement would increase apparent specificity without increasing truth.

XIV. Recovery and Disclosure Consequences

A failed generation is observable through error categories such as invalid schema, unsupported claim, or model unavailability. The repair prompt contains only those categories and the same snapshot. It cannot ask for raw logs or expand the recipient's authorization. If it still fails, the deterministic fallback carries a reason and snapshot digest. This is operationally different from silently returning an empty report: analysts can see that explanation generation failed while the underlying incident remains available.

The fallback can also protect against a denial-of-service pattern in which repeated prompts consume CPU time. It bounds attempts to two, but the measured 146.7-second median for the complete condition shows that a call count alone is not an acceptable latency service level. Production use would need stricter time budgets, workload admission, and measurements under concurrency. A smaller model may be faster but might fail the claim contract more often; a larger or GPU-hosted model might improve formatting but change memory and deployment costs. The paper makes no cross-model ranking from one measured configuration.

Every generation attempt sends the authorized snapshot to the configured local endpoint. If that endpoint moves to another laptop, the transport becomes an additional trust boundary. Authenticated TLS and a recipient-scoped snapshot reduce exposure, but neither makes derived security evidence harmless. The model service should be treated as part of the same security domain or a separately authorized recipient. There is no automatic cloud fallback. This keeps data location explicit while preserving a deterministic report when the remote model is unavailable.

XV. Failure Budget for an Interactive Workflow

The measured generation times are incompatible with an assumption of instantaneous analyst assistance on the tested CPU. A practical deployment should define a deadline for explanatory text separately from the detector's deadline. The detector and incident workflow can return immediately with a rule outcome and coverage status; the explanation job may remain pending or fall back. If the model misses its deadline, the API should not quietly relabel the incident as benign, nor should it serve a report from an earlier evidence digest. A

visible pending or template state makes the latency trade-off reviewable.

Moving inference to a stronger second laptop may reduce time, but it introduces network delay, TLS configuration, endpoint authentication, and a new failure domain. The coordinator should send only the snapshot authorized for that recipient, bound the request body, and refuse an endpoint with an invalid certificate or key. If the remote service disappears, the deterministic report remains available locally after current authorization succeeds. A performance study should measure that fallback path separately from successful model generation. The present eight cases do not simulate transport loss or concurrent clients, so they cannot establish a service-level objective for the two-laptop configuration.

XVI. Withdrawals Corrections and Report Versions

A report is an interpretation of a particular authorized snapshot. Evidence changes should therefore create a new report version rather than silently update the text beneath an old identifier. The record names the authorized snapshot digest and each cited evidence identifier/version. The current service marks a report stale when its snapshot digest changes; a finer-grained dependency index could avoid regenerating unrelated observations but is not part of the pilot.

Corrections and revocations have different meanings. A correction states that an earlier value was inaccurate or incomplete and supplies a replacement. A revocation may withdraw permission without saying the earlier value was false. The explanation must not turn an authorization change into a factual contradiction. It can indicate that an earlier statement is no longer supportable from currently authorized inputs, where that status disclosure is allowed.

Suppose a report said that a sensor observed a high-rate bin. The underlying record is later corrected to medium. The revised report names the corrected bin and records that the old report was superseded. If the record is instead revoked, the revised report omits the value and preserves only permitted status. A copied paragraph in a cache is still a disclosure surface; cached explanations must follow the same evidence dependencies and authorization checks as newly generated text.

There is a limit to what invalidation accomplishes. An analyst may already have exported the report or acted on its content. The system can issue a correction or withdrawal notice, but cannot guarantee remote erasure or reversal of a human decision. Our pilot checks current-snapshot admission but does not measure propagation delay to external copies.

The timing of invalidation is operationally significant. A future latency study should measure from an evidence update to the point where affected reports are marked stale and new requests stop using them, including queue delay and cache lifetime. The present API checks a stored digest before returning a report. That provides a stronger current-snapshot boundary at additional database and availability cost; it is not a guarantee that already-exported copies disappear.

XVII. Assessing Useful Abstention

Abstention protects against unsupported specificity, but it can also make a system unhelpful. An explanation that says nothing has no unsupported factual claims. Evaluation must reward coverage of relevant supported facts while penalizing invented or contradicted statements. This is why the proposed study separates factual precision from useful coverage instead of collapsing them into one score.

Let N_f be the number of generated factual claims, N_u the number judged unsupported, and N_r the number of relevant supported facts identified by reviewers. Report N_u/N_f when $N_f > 0$, and report the supported relevant facts conveyed divided by N_r when $N_r > 0$. Empty denominators are reported as not applicable with their case counts. They are not assigned a perfect score. Reviewer relevance judgements require a written rubric and cannot be inferred from overlap with a model-generated reference answer alone.

Contradiction preservation needs a separate assessment. A report may correctly quote one source while concealing an authorized conflicting record. Such a report can look factually supported at the sentence level and still mislead the analyst. The evaluation rubric should ask whether material conflicts and uncertainty that change the incident interpretation are disclosed. It should distinguish an omitted irrelevant detail from omission of a decisive qualification.

Analyst usefulness can be assessed through bounded questions about the supplied evidence: what is known, what is unknown, what needs confirmation, and which action requires authorization. Compare task accuracy and time using counterbalanced presentation of reports, with appropriate participant consent and study approval where required. A preference for fluent prose is not equivalent to improved decision quality. The present manuscript contains no participant data or claim that such a study has occurred.

Report results by evidence condition as well as in aggregate. A model may perform well on complete cases but fail specifically when counts are withheld or records are revoked. Aggregating across a predominance of easy cases can obscure that weakness. The contract's intended contribution concerns these difficult evidence states, so their individual outcomes are central to its evaluation.

XVIII. State Transition Walkthrough

Consider an incident with version 1 and an authorized evidence item e whose value is high. A report can name $(e, 1, \text{high})$ if the item is active and the recipient may see it. A sensor later corrects that item to medium at version 2. The item identifier alone still resolves, but the old tuple is no longer permitted. The snapshot digest changes, so a previously stored report is returned as stale; a fresh report may say medium only if the recipient is still authorized. This distinction matters because simply rewriting a citation to point to version 2 would leave the old word high in the sentence. A valid correction recomputes the claim and the rendered text.

Withdrawal differs. If e becomes inactive, the current expected-claim set contains no evidence-value claim for it.

TABLE VI
REQUIRED REPORT HANDLING ACROSS EVIDENCE CHANGES.

Change	Controlled explanation response
Value corrected	Old digest stale; recompute current value and version
Item withdrawn	Old digest stale; omit withdrawn value
Scope removed	Deny recipient request regardless of prior report
Unchanged digest	Existing authorized report may be returned after access check
Model unavailable	Current deterministic fallback; no change to incident decision

The service may still know that a report existed historically, but it cannot show its withdrawn value through the current explanation path. If an authorization change removes access to an incident, the API should deny the report request entirely rather than expose even a stale summary. Staleness is a report-validity state, not a substitute for access control. Audit retention, if needed, has a separate purpose and audience.

The table describes the intended boundary of the implemented API, not a claim of erasure from all downstream locations. A screenshot, exported PDF, analyst memory, or disconnected browser cache may contain the old text. The system can mark its own job stale and withhold it from new requests; it cannot guarantee that every copy is destroyed. A deployment that sends alerts by email or to another ticketing system would need an explicit correction protocol for those channels. The pilot did not measure such propagation.

The current invalidation granularity is a whole snapshot. This is conservative because any digest change invalidates a report even if a changed evidence item was never cited. A claim-level dependency graph could preserve unaffected statements, but it would require every implicit dependency to be represented. For example, an outcome sentence may depend on several supporting observations even when it does not cite each one. If that hidden relationship is missed, fine-grained invalidation could serve a stale conclusion. The coarse digest check trades regeneration cost for a simpler safety argument.

XIX. Authorization as a Time-Varying Input

Permission is evaluated at two times: when the snapshot is constructed for generation and when a report is retrieved. The first check prevents the model from seeing evidence outside the recipient's scope. The second prevents a previously authorized report from being served after permission changes. The stored digest binds output to snapshot contents but is not itself an access token. Guessing a job identifier should not grant access; the API must verify the user and incident scope for every fetch. The pilot's finite scorer does not exercise browser sessions or cross-organization access and therefore cannot validate those controls; they belong to the application integration tests.

A lifecycle test should include an in-flight job. If permissions are revoked after generation starts but before the worker stores the output, the worker must compare its snapshot digest with the current authorized snapshot before publishing. If the job was completed before revocation, the read path must still deny or mark it stale. There are two race windows, and closing only one is insufficient. The service's current worker and HTTP read paths both check for a digest mismatch; a future formal analysis could state linearization points and prove the absence of a served stale report under concurrent updates.

Authentication and authorization are separate. A valid browser session proves the identity of a user, while incident-scoped permissions determine which snapshots that user may read. A second-laptop model endpoint has a machine credential and TLS channel but no independent right to fetch arbitrary incidents. It receives only the snapshot the API already approved. If that machine is compromised, it can read the snapshots sent to it during its authorized operation. This is a residual risk of moving inference off the primary PC, even though no external cloud provider is contacted.

An authorization check can fail because the database is unavailable. Serving an old report in that state would convert a temporary outage into a disclosure decision. The safer response is a visible unavailable status or a fallback built only after current authorization can be established. The distinction is operationally costly: an analyst may lose an explanation during a database incident. For sensitive cross-organization data, that cost is preferable to silently reusing a stale authorization decision. The evaluation does not quantify that availability trade-off.

XX. Contract Invariants and Their Preconditions

The reference invariant is that every displayed evidence-value sentence names an evidence item in the recipient's current snapshot with the same version and value. This follows from computing allowed tuples from that snapshot and rendering only admitted tuples. It assumes the snapshot constructor has already enforced access and that the renderer does not append unchecked model prose. The invariant does not make the sensor accurate. It does not apply to an image of an earlier report taken before a correction.

The kind invariant is that a partial-coverage field cannot be rendered as a complete observation. The expected-claim constructor maps partial coverage to an unknown claim. The template text says that unavailable evidence cannot establish absence of threat. A model that tries to convert partial coverage into a reassuring observation fails tuple membership. The strength of this rule depends on coverage being accurately represented upstream. If the incident API incorrectly labels a partial snapshot complete, the explanation layer cannot discover the omission.

The version invariant is that a completed report is usable only while its digest matches a newly authorized snapshot for the requesting user. This is enforced on retrieval and also checked by the worker before storing a result. A digest mismatch makes the job stale. The digest is an equality token over snapshot state, not a cryptographic proof of source authenticity. If two distinct security states produce an identical digest through a construction bug, this invariant fails. Testing

must therefore include version changes, deactivation, and permission changes and verify that each changes the authorized view or blocks access.

The bounded-attempt invariant is that a model request is attempted at most twice: one initial generation and one repair. This prevents an unbounded autonomous loop. It says nothing about how long either call takes until a timeout is configured and enforced. An exception also ends in deterministic fallback, which keeps detection independent of model availability. The pilot's median generation time shows that the operational limit must be expressed in seconds and resource reservations, not just attempt count.

Finally, the no-action invariant is that the explanation component has no remediation tool. A suggestion to review local logs is represented as advice and rendered as a suggestion to an authorized analyst. It cannot launch a query or change an incident. This reduces the damage from a malicious instruction in evidence. It does not prevent a human analyst from acting on misleading advice, so user-facing labels and review procedures remain part of the larger safety case.

These invariants are deliberately narrow. None claims that the output is a complete, unbiased, or strategically useful account of an incident. A new predicate, renderer, or external delivery channel changes the proof obligations. Treating the verifier as a stable interface requires contract-versioning and regression tests whenever the vocabulary expands. The present study is a reproducible baseline for that work, not a claim of final coverage.

XXI. Conclusion

Versioned authorized snapshots, finite claim admission, and controlled rendering make missing and withdrawn information explicit in local alert explanations. In eight frozen cases the complete method rejected unsupported outputs, yet fell back every time and had much higher latency than templates. The result establishes a reproducible safety boundary and a clear negative utility result for the tested model configuration. It does not establish source truth, human usefulness, or field reliability.

a) Acknowledgments: AI assistance.: OpenAI ChatGPT through Codex assisted with literature discovery, method formulation, drafting, and editing, including the abstract and references. The authors remain responsible for verifying every claim and complying with the selected venue's disclosure requirements. All reported measurements are from the accompanying local pilot; examples are constructed.

References

[1] M. Rigaki, C. Catania, and S. Garcia, "Hackphyr: A Local Fine-Tuned LLM Agent for Network Security Environments," arXiv:2409.11276, 2024, doi: 10.48550/arXiv.2409.11276.

[2] N. Suryanto *et al.*, "RedSage: A Cybersecurity Generalist LLM," in *Proc. ICLR*, 2026. [Online]. Available: https://openreview.net/pdf?id=W4FAenIrQ2

[3] T. Gao, H. Yen, J. Yu, and D. Chen, "Enabling Large Language Models to Generate Text with Citations," in *Proc. EMNLP*, 2023, pp. 6465–6488, doi: 10.18653/v1/2023.emnlp-main.398.

[4] L. Gao *et al.*, "RARR: Researching and Revising What Language Models Say, Using Language Models," in *Proc. ACL*, vol. 1, 2023, pp. 16477–16508, doi: 10.18653/v1/2023.acl-long.910.

[5] S. Min *et al.*, "FActScore: Fine-grained Atomic Evaluation of Factual Precision in Long Form Text Generation," in *Proc. EMNLP*, 2023, pp. 12076–12100, doi: 10.18653/v1/2023.emnlp-main.741.

[6] M. Atoum, M. Al-Essa, Y. Alsarhan, A. K. A. Hwaitat, and M. Imran, "LLM Enhanced Explainable Intrusion Detection System for Generating Actionable Security Insights," *Computers, Materials & Continua*, vol. 89, no. 2, Art. no. 50, 2026, doi: 10.32604/cmc.2026.085403.

[7] E. Eilertsen, V. Mavroeidis, and G. Grov, "Towards Agentic Investigation of Security Alerts," in *Proc. IEEE BigData*, 2025, pp. 7793–7802, doi: 10.1109/BigData66926.2025.11402161.

[8] F. A. Kamelhar, "GSAR: Typed Grounding for Hallucination Detection and Recovery in Multi-Agent LLMs," arXiv:2604.23366, 2026, doi: 10.48550/arXiv.2604.23366.

[9] Y. T. Shen, K. Toyoda, and A. Leung, "Revoked but Still Authoritative: An Empirical Study of Revocation Enforcement in Agent-Memory Systems," arXiv:2609.08258, 2026, doi: 10.48550/arXiv.2609.08258.

[10] N. Srisumrith and S. Sodsee, "Detecting Cybersecurity Threats by Integrating Explainable AI with SHAP Interpretability and Strategic Data Sampling," arXiv:2602.19087, 2026, doi: 10.48550/arXiv.2602.19087.

[11] X. Hu *et al.*, "Knowledge-Centric Hallucination Detection," in *Proc. EMNLP*, 2024, pp. 6953–6975, doi: 10.18653/v1/2024.emnlp-main.395.

[12] P. Manakul, A. Liusie, and M. Gales, "SelfCheckGPT: Zero-Resource Black-Box Hallucination Detection for Generative Large Language Models," in *Proc. EMNLP*, 2023, pp. 9004–9017, doi: 10.18653/v1/2023.emnlp-main.557.

[13] Y.-N. Chuang *et al.*, "FaithLM: Towards Faithful Explanations for Large Language Models," in *Proc. EACL*, vol. 1, 2026, pp. 3802–3824, doi: 10.18653/v1/2026.eacl-long.177.

[14] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," in *Proc. ACM AISec*, 2023, pp. 79–90, doi: 10.1145/3605764.3623985.

[15] K. Vaswani *et al.*, "Confidential Computing within an AI Accelerator," in *Proc. USENIX ATC*, 2023, pp. 501–518. [Online]. Available: https://www.usenix.org/conference/atc23/presentation/vaswani

[16] A. Yang *et al.*, "Qwen3 Technical Report," arXiv:2505.09388, 2025, doi: 10.48550/arXiv.2505.09388.

[17] L. Yuan, D.-J. Han, S. Wang, and C. G. Brinton, "Local-Cloud Inference Offloading for LLMs in Multi-Modal, Multi-Task, Multi-Dialogue Settings," in *Proc. ACM MobiHoc*, 2025, pp. 201–210, doi: 10.1145/3704413.3764429.